Nätverksdesign – Switching & Routing

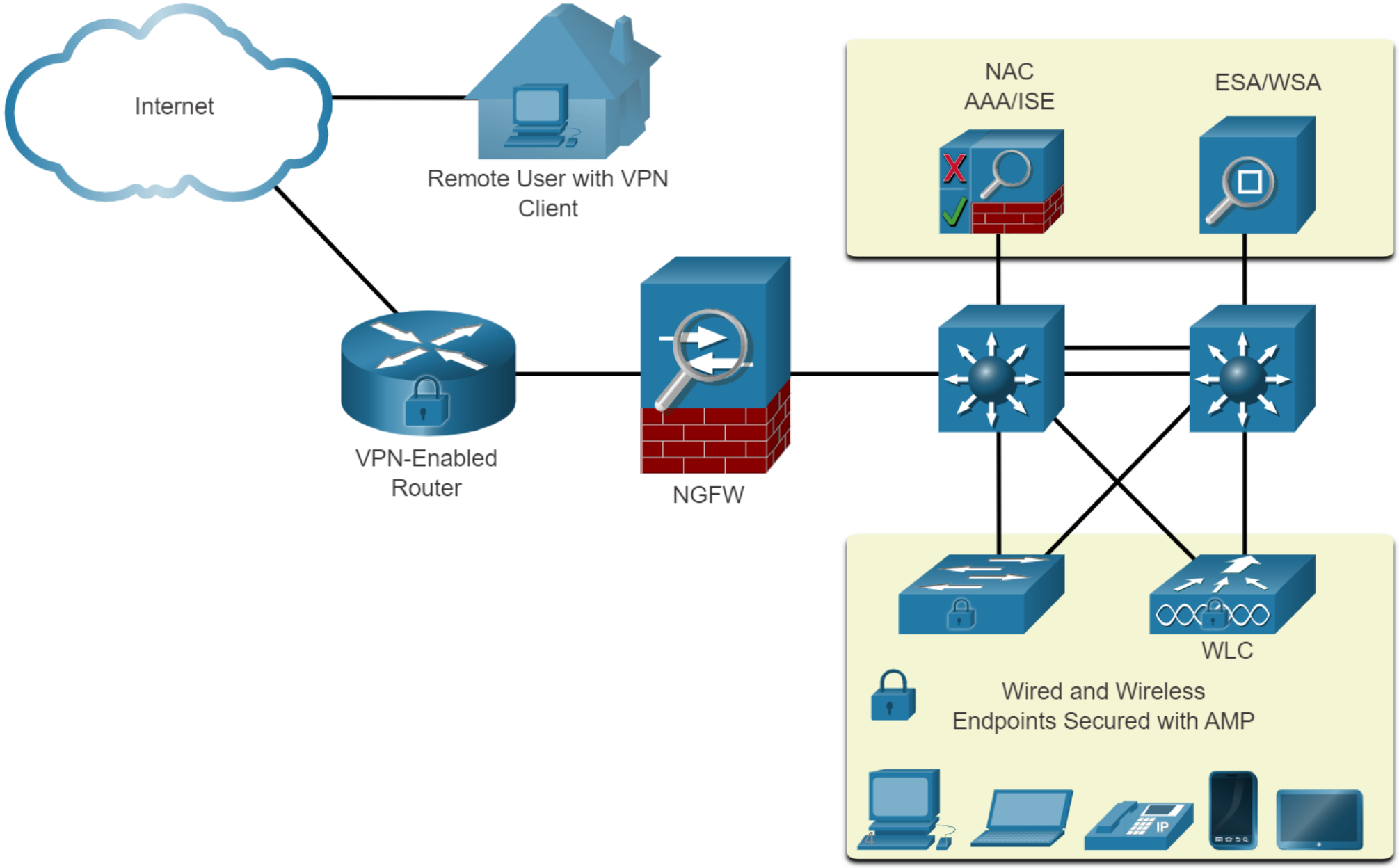
LAN-säkerhet

Skadliga nätverksattacker

- De vanligaste inkluderar:
  - Distributed Denial of Service (DDoS)
  - Stöld/läckor av hemlig information
  - Skadlig kod

Säkerhet på endpoints

- Klassisk endpoint security:
  - IPS (Host-based IPS)
  - Brandvägg (Host-based Firewall)
  - Antivirus och antimalware
- Nya verktyg:
  - AMP
  - ESA
  - WSA

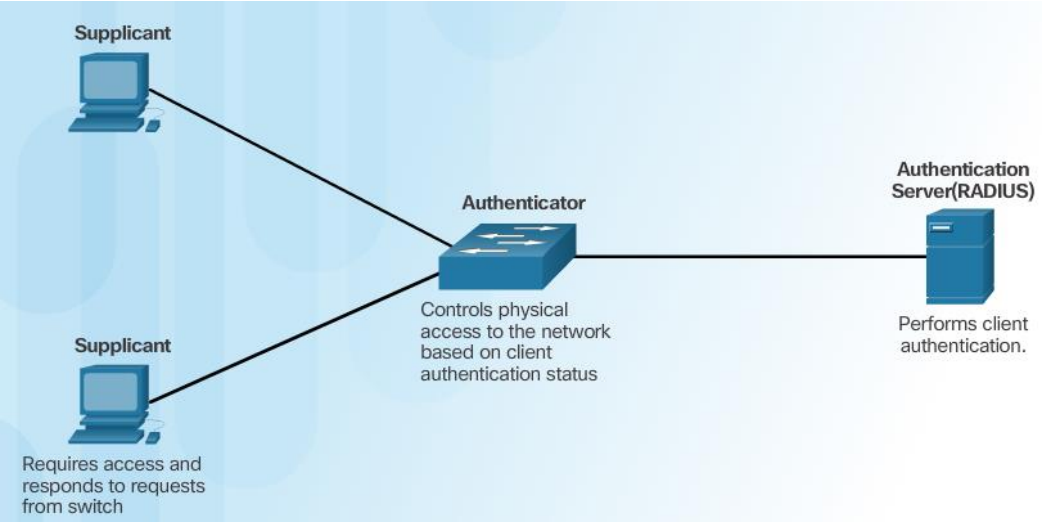

Internet
Remote User with VPN Client
NAC
AAA/ISE
ESA/WSA
VPN-Enabled Router
NGFW
WLC
Wired and Wireless
Endpoints Secured with AMP

Säkerhet med AAA

- **Authentication** – Vem är du?
  - Inloggning, grunden för all säkerhet. När man vet vem kan man bestämma rättigheter, logga osv
- **Authorization** – Vad får du göra?
  - När man vet VEM som är inloggad kan man bestämma VAD som får göras
    - Rättigheter i filsystem
    - Tillgängliga kommandon i Cisco IOS
- **Accounting** – Vad har du gjort?
  - När man vet VEM som är inloggad kan man logga VAD som har hänt

Säkra portarna i lokala nätverk (802.1x)

- **802.1x** gör att AAA kan användas på det lokala nätverket
- Standarden definierar tre olika roller
  - **Supplicant** (t.ex. en klient)
  - **Authenticator** (t.ex. en switch)
  - **Authentication server** (t.ex. en AAA-server)



Säkerhet på lager 2 (switchar)

- När man tänker på nätverkssäkerhet är det första man tänker på oftast brandväggar
- Kollar man tidigare attacker är dock attacker från insidan oftast de värsta
- En läcka på lager 2, påverkar alla ovanstående lager
- Att säkra upp sin LAN-miljö är därför en utav nyckelkomponenterna i hela säkerhetsstrategin

Attacker mot Lager 2

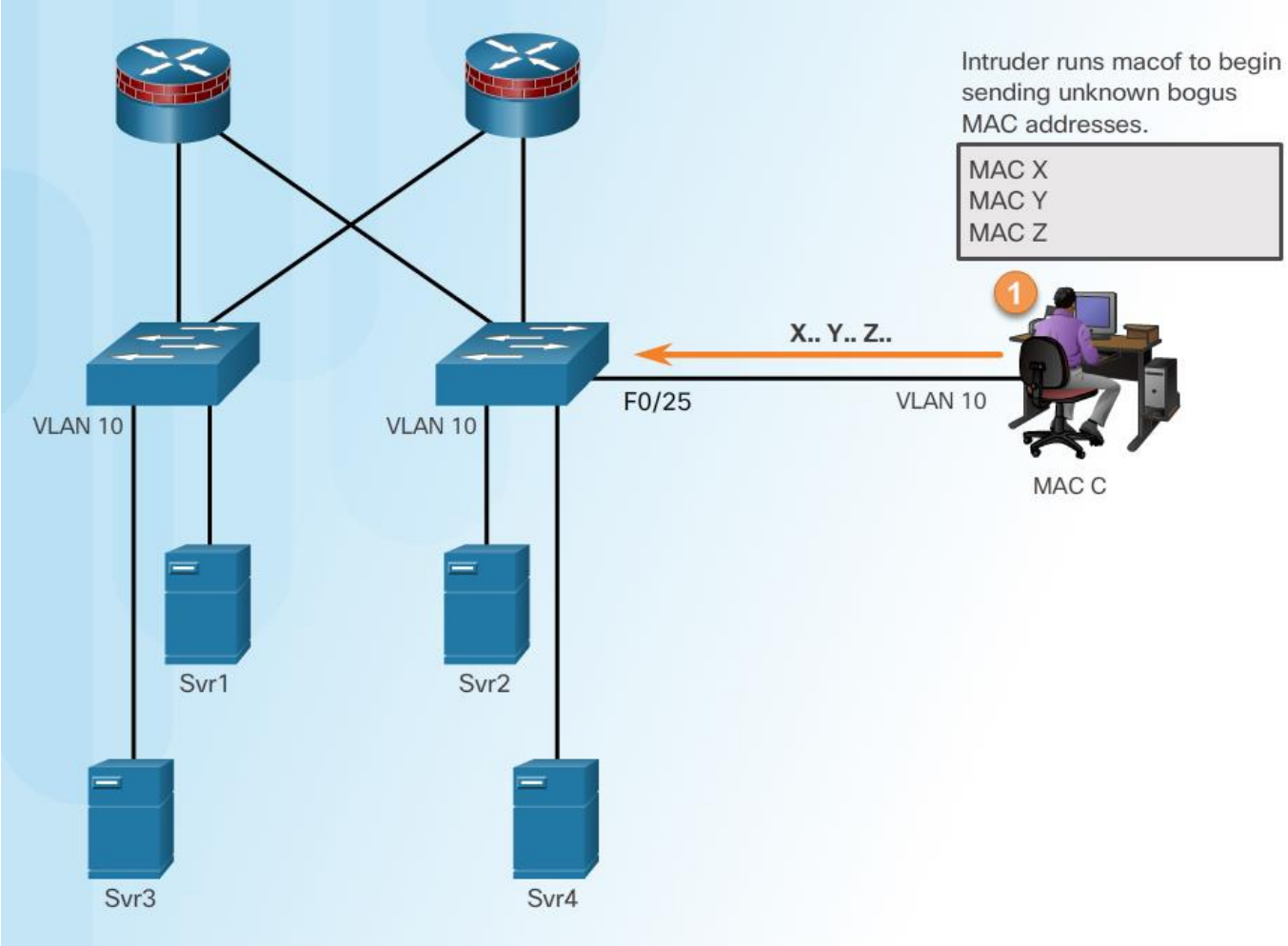
- **MAC-tabellattacker**
  - Attacker mot Content-addressable memory (CAM)
- **VLAN-attacker**
  - Inkluderar VLAN hopping och VLAN double-tagging
- **DHCP-attacker**
  - Inkluderar bland annat DHCP starvation och DHCP spoofing
- **ARP-attacker**
  - Inkluderar ARP spoofing
- **Address Spoofing-attacker**
  - Spoofing av MAC och/eller IP
- **STP-attacker**
  - Manipulation av Spanning-Tree Protocol (STP)

Motverka attacker

- **Port Security**
  - Motverkar attacker mot CAM-tabellen och DHCP starvation
- **DHCP Snooping**
  - Motverkar DHCP spoofing
- **Dynamic ARP Inspection (DAI)**
  - Motverkar ARP spoofing
- **IP Source Guard (IPSG)**
  - Motverkar spoofing-attacker på lager 2 och 3

Attack mot CAM-tabellen

- Felaktiga MAC-adresser läggs till i CAM-tabellen
- Ett attackverktyg (pentesting) är **macof**
- När tabellen är full skickas frames ut på alla portar i samma VLAN



Port Security

- Ett sätt att skydda sig mot CAM-tabellattacker är **Port security**
- **Port security** kan användas för att begränsa antalet source-MAC som tillåts på en port. Konfiguration:

```
S1(config)# interface gi0/0
S1(config-if)# switchport port-security
```

- Med standardinställningar tillåts endast 1 MAC samtidigt, vid överträdelse stängs porten av. För att öka detta:

```
S1(config-if)# switchport port-security maximum 5
```

Port Security

- Det går också ställa in statiskt vilka MAC-adresser som tillåts på porten:

```
S1(config-if)# switchport port-security mac-address abcd.abcd.abcd
```

- Alternativt kan switchen lära sig MAC-adresser dynamiskt:

```
S1(config-if)# switchport port-security mac-address sticky
```

Port Security Aging

- Port Security Aging är den tiden som en MAC-adress sparas
- Indelat i två delar; *absolute* och *inactivity*
  - **Absolute** – Efter en viss tid tas adressen bort
  - **Inactivity** – Efter inaktivitet i en viss tid tas adressen bort
- Konfiguration enligt nedan:

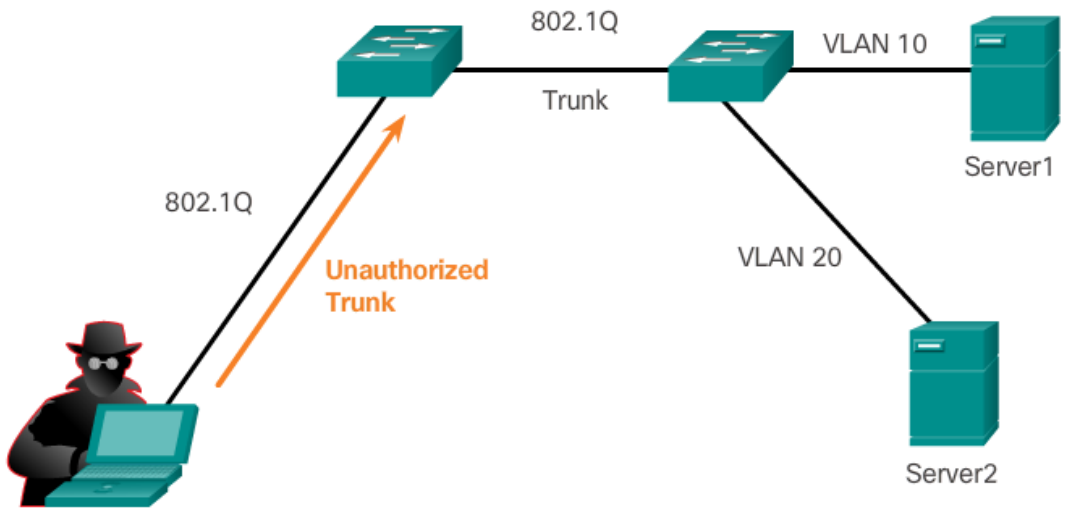
```
S1(config-if)# switchport port-security aging time 10
S1(config-if)# switchport port-security aging type inactivity
```

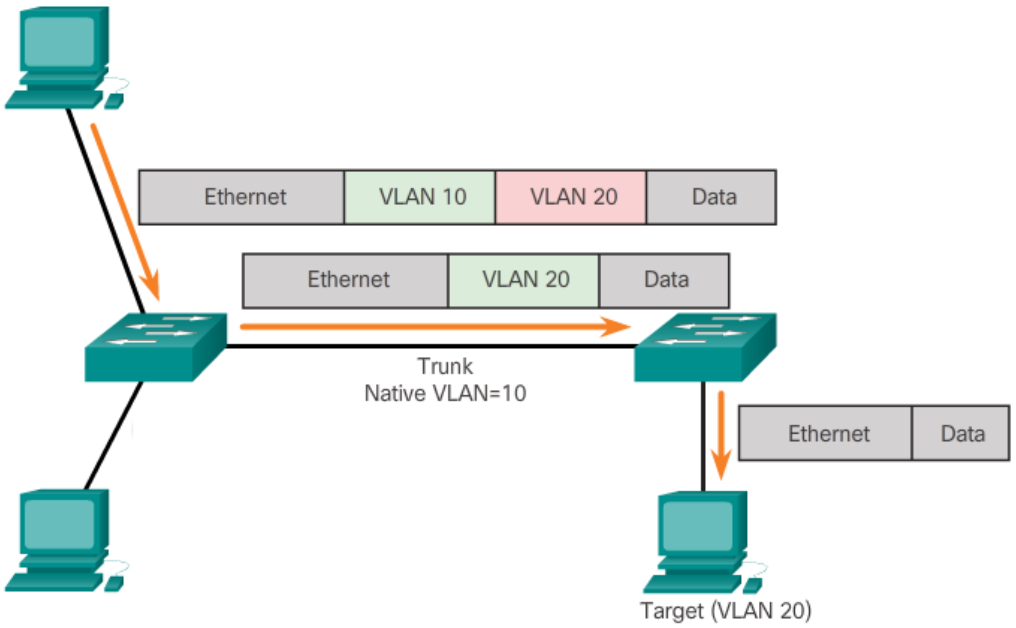
Port Security Violations

- Vid en överträdelse finns tre olika *violations;*
- **Protect**
  - Minst säker
  - Vid en överträdelse slängs frames från den okända MAC-adressen
  - Ingen notifikation skickas till administratören
- **Restrict**
  - Samma som *protect* med tillägget att en notifikation skickas till administratören
- **Shutdown**
  - Standardläge och det säkraste
  - Vid en överträdelse blir porten ***error-disabled***

Säkerhet med VLAN

- **Switch Spoofing Attack**
  - Utnyttjar DTP mot en klientport
  - **Lösning:** Stäng av DTP helt
- **Double Taggning Attack**
  - Utnyttjar Native VLAN:
    1. Klient sitter på samma VLAN som Native VLAN och skickar ut ett paket med dubbla VLAN-taggar
    2. Switchen tar sedan bort första taggen (native VLAN)
    3. Klienten har tillgång till valfritt VLAN (t.ex. servrar)
  - **Lösning:** Använd ett separat VLAN för Native VLAN



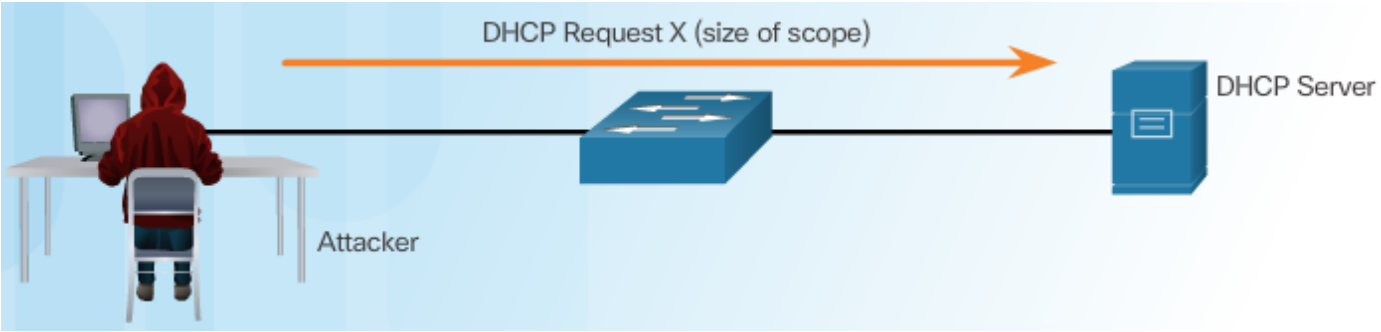


“Best practice”

- Skapa ett **“black hole”-VLAN** för oanvända portar
- Stäng av portar som är oanvända (**shutdown**)
- Ha ett separat **Management VLAN (MGMT)**
- Ha ett separat VLAN för **Native VLAN**
- Använd aldrig **DTP** för att förhandla om trunk, stäng även av det på access-portar

DHCP Starvation

- Som namnet antyder innebär det att DHCP-servern *scope* fylls upp av skräputlåningar
- Eftersom *scopet* töms räknas det som en DoS-attack
- **Lösning:** Port-security hindrar denna attack

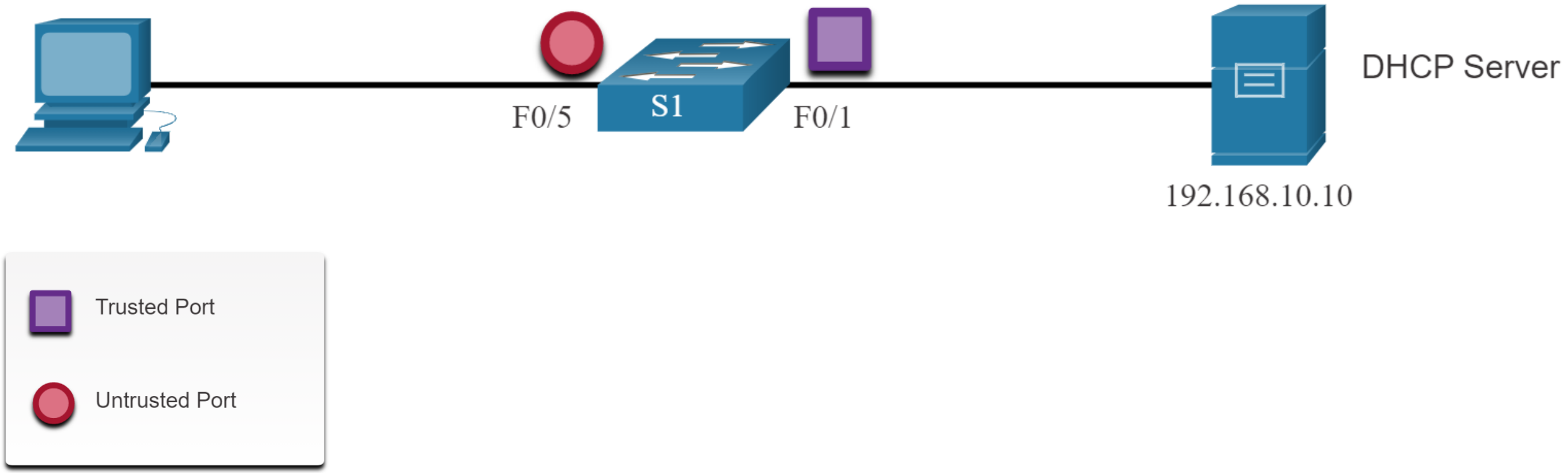


DHCP Spoofing

- Innebär att någon sätter upp en otillåten DHCP-server i nätverket
  - Finns både medvetna och omedvetna varianter
- Servern kan genom att göra detta exempelvis ändra:
  - Default gateway (MITM)
  - DNS-server (typ MITM)
  - IP-adress (DoS)
- **Lösning:** DHCP Snooping

DHCP Snooping

- Portar ställs i *trusted* och *untrusted*



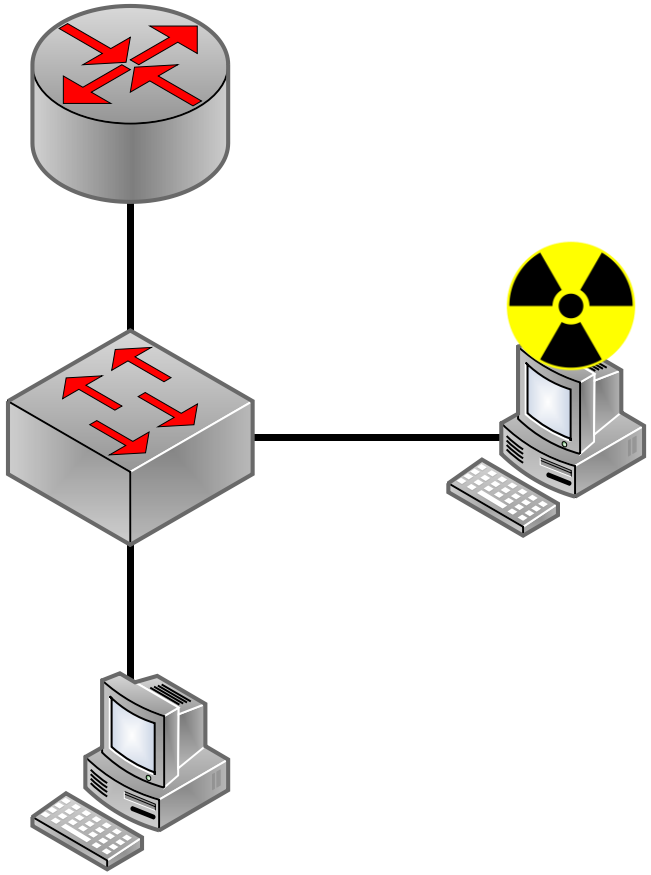
DHCP Snooping - Konfiguration

- **Steg 1:** Sätt igång DHCP Snooping globalt
- **Steg 2:** Ställ in vilka portar som är *trusted*
- **Steg 3:** Sätt igång DHCP Snooping på berörda VLAN

```
S1(config)# ip dhcp snooping
S1(config)# interface g0/1
S1(config-if)# ip dhcp snooping trust
S1(config-if)# exit
S1(config)# ip dhcp snooping vlan 10,20-23
```

ARP Spoofing/Poisoning

- **ARP** används för att översätta från IP-adress till MAC-adress för kommunikation i det lokala nätverket
- Bygger på att man spoofar en **Gratuitous ARP** där man säger att MAC-adressen för exempelvis default gateway har ändrats
- Detta i sin tur blir vanligtvis en **MITM** (Man-in-the-Middle)-attack där alla trafik går via hackerns dator innan det går ut via routern
- Verktyg: Cain & Abel (Windows), arpspoof (Linux)



Dynamic ARP Inspection (DAI)

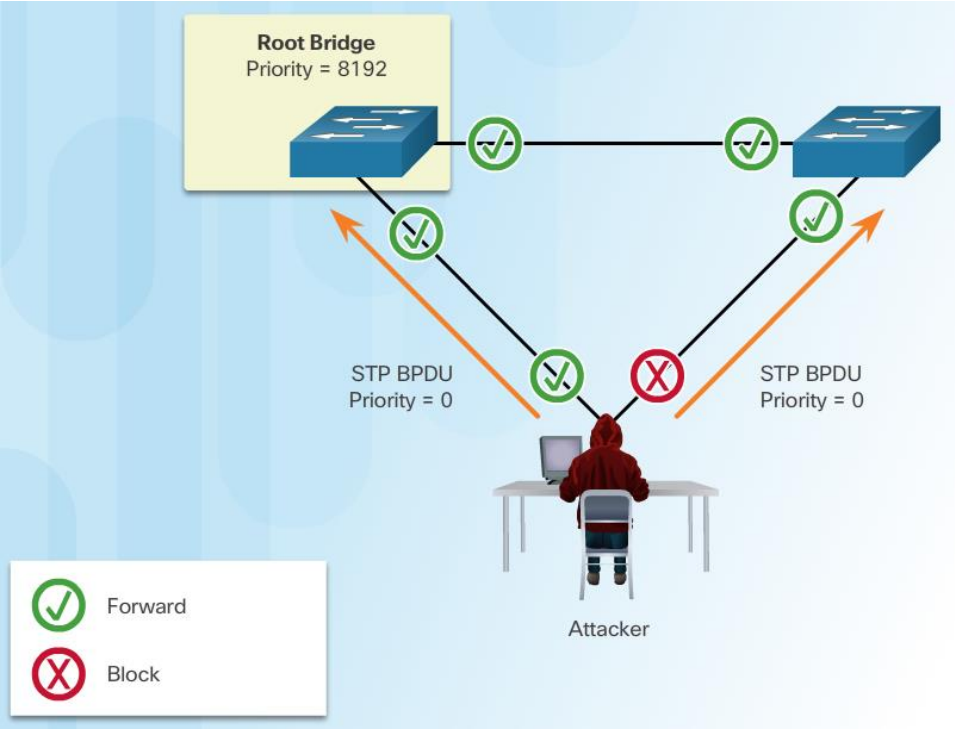
- För att skydda sig kan man använda sig av **DAI**
- Bygger på DHCP Snooping (tabellerna som är skapade används av DAI)

```
S1(config)# interface g0/1
S1(config-if)# ip arp inspection trust
S1(config-if)# exit
S1(config)# ip arp inspection vlan 10
```

- Alternativt kan man skapa ARP-ACL:er

Manipulation av STP-processen

- Genom att skicka egensnickrade BPDU:er kan en hacker bli rootbrygga i nätverket
- **Lösning:** BPDU Guard



JÖNKÖPING UNIVERSITY

School of Engineering